

GUIDE PRATIQUE IT : CYBERSÉCURITÉ 2026

Thématiques : OWASP, Nouvelles Menaces, Réponse à Incident & Défense Active

1. Panorama OWASP & Nouvelles Menaces (2026)

Le paysage des menaces en 2026 est profondément marqué par l'utilisation offensive de l'intelligence artificielle générative et l'hyper-complexité des architectures microservices.

A. Les risques liés à l'IA générative et aux LLM

- Injection de Prompts Indirecte : les applications connectées à des modèles de langage (LLM) qui récupèrent des données externes peuvent être compromises par des instructions malveillantes invisibles.
- Empoisonnement des données d'entraînement : altération des bases de connaissances vectorielles (RAG) afin d'induire en erreur un assistant virtuel d'entreprise.

B. OWASP API Security Top 10

- BOLA (Broken Object Level Authorization) : manipulation d'identifiants d'objets pour accéder aux données d'autres utilisateurs.
- Exposition excessive de données : les API renvoient des objets complets contenant parfois des informations sensibles (PII, mots de passe hachés, etc.).

C. Sécurité de la Supply Chain Logicielle

Les attaques ciblent les dépendances (npm, PyPI, Composer) et les chaînes CI/CD afin d'introduire des portes dérobées dans les applications de production.

2. Méthodologie d'Incident Response (IR)

Cycle standard : Préparation → Détection & Analyse → Confinement & Éradication → Retour d'Expérience

Confinement immédiat

Isoler la machine compromise du réseau. Ne jamais éteindre brutalement un système si une analyse mémoire est nécessaire.

Collecte des preuves

Récupérer les journaux Windows (Security.evtx, System.evtx), les logs Linux (/var/log/auth.log, /var/log/syslog), l'historique des commandes et les tâches planifiées.

Éradication & remédiation

Supprimer les comptes malveillants, réinitialiser les mots de passe privilégiés et appliquer les correctifs de sécurité.

Restauration

Reconstruire les systèmes à partir de sauvegardes saines et vérifier leur intégrité avant remise en production.

3. Check-list de Durcissement (Hardening)

- Authentification multifacteur (MFA) avec FIDO2 / WebAuthn.
- Principe du moindre privilège (PoLP) pour tous les comptes administrateurs.
- Journalisation centralisée (SIEM / Syslog) vers un serveur distant inaltérable.
- Scans réguliers des vulnérabilités (Nessus, OpenVAS) et veille CERT.

Édition 2026 — Guide de révision en cybersécurité.